LADEKLAR

RECHTLICHE MUSTER

Technische und organisatorische Maßnahmen (TOM) nach Art. 32 DSGVO

Hinweis – Muster, keine Rechtsberatung.

Technische und organisatorische Maßnahmen (TOM) nach Art. 32 DSGVO

> **Hinweis – Muster, keine Rechtsberatung.** Dieses Dokument ist ein Mustertext für LADEKLAR. Es ersetzt keine Rechtsberatung und ist vor Verwendung anwaltlich prüfen zu lassen. Platzhalter in [eckigen Klammern] ausfüllen. Mit „Prüfhinweis“ gekennzeichnete Anmerkungen sind vor Verwendung zu entfernen. Die TOM müssen der tatsächlichen Umsetzung entsprechen; jede Angabe ist vor Veröffentlichung technisch zu bestätigen. Recherchestand: 16.10.2026.

Anlage 2 zum Auftragsverarbeitungsvertrag von [Firma] [Rechtsform] („Anbieter“)

Stand: [Datum] · Version [1.0] · verantwortlich für die Pflege: [Name, Funktion]

1. Grundlagen

(1) Die Maßnahmen berücksichtigen den Stand der Technik, die Implementierungskosten, Art, Umfang, Umstände und Zwecke der Verarbeitung sowie die Risiken für die Rechte und Freiheiten der betroffenen Personen (Art. 32 Abs. 1 DSGVO). Besonderes Gewicht haben die Vertraulichkeit von Beschäftigtendaten, die Integrität von Abliefernachweisen und die Verfügbarkeit während laufender Touren.

(2) Systemüberblick: Server in Node.js 22 ohne Web-Framework, Datenbank SQLite (`node:sqlite`), Live-Aktualisierung per Server-Sent Events, Web-Push mit VAPID, Web-App und installierbare PWA, optional Store-App (Capacitor). Betrieb ausschließlich in einem Rechenzentrum in Deutschland.

(3) Die Spalte „Status“ ist vor Veröffentlichung auszufüllen: **U** = umgesetzt, **G** = geplant bis [Datum].

2. Vertraulichkeit (Art. 32 Abs. 1 lit. b DSGVO)

2.1 Zutrittskontrolle

Maßnahme	Status
Betrieb ausschließlich in einem Rechenzentrum von [Hosting-Anbieter] in [Ort], Deutschland, zertifiziert nach ISO/IEC 27001	[U/G]
Physische Sicherheit durch das Rechenzentrum: Zutritt nur für berechtigte Personen, Videoüberwachung, Einbruchmeldeanlage, Protokollierung, Brandschutz (Nachweis durch Zertifikat des Rechenzentrums)	[U/G]
Keine eigenen Server- oder Datenträgerstandorte des Anbieters; Arbeitsplätze ohne lokale Kopien von Kundendaten	[U/G]

2.2 Zugangskontrolle (Systeme)

Maßnahme	Status
Transportverschlüsselung aller Verbindungen mit TLS 1.2 oder höher, HSTS; unverschlüsselte Verbindungen werden umgeleitet	[U/G]

Maßnahme	Status
Passwörter von Admins und Disponenten werden mit scrypt und individuellem Salt gehasht (Parameter [N, r, p]); Klartext-Passwörter werden nicht gespeichert	[U/G]
Fahrer-PINs (sechsstellig) werden ebenfalls mit scrypt und Salt gehasht; wegen der geringen Länge der PIN ist die Login-Sperre zwingender Bestandteil	[U/G]
Login-Sperre nach [5] Fehlversuchen für [15] Minuten je Zugang, zusätzlich Begrenzung je IP-Adresse; Protokollierung fehlgeschlagener Versuche	[U/G]
Sitzungs-Tokens mit mindestens 256 Bit Zufall; in der Datenbank nur als Hash (SHA-256) gespeichert	[U/G]
Sitzungs-Cookie mit den Attributen `HttpOnly`, `Secure` und `SameSite=[Lax/Strict]`; Laufzeit höchstens 90 Tage; Abmelden und PIN-Reset beenden alle Sitzungen des Nutzers	[U/G]
Startpasswort für Admins muss bei der ersten Anmeldung geändert werden	[U/G]
Einladungslinks für Fahrer sind [einmalig verwendbar und [72] Stunden gültig] und erfordern zusätzlich die PIN	[U/G]
API-Schlüssel (Premium) werden nur als Hash gespeichert, sind je Mandant widerrufbar und unterliegen einer Anfragebegrenzung	[U/G]
Server-Administration nur über SSH mit Schlüssel, ohne Passwort-Anmeldung; Zugang für [Anzahl] namentlich benannte Personen; Protokollierung	[U/G]
Zwei-Faktor-Authentifizierung für die Plattform-Konsole des Anbieters, den Support-Modus und die Konten beim Hosting-Anbieter	[U/G]
Zwei-Faktor-Authentifizierung als Option für Admins der Kunden	[G]

2.3 Zugriffskontrolle (Daten)

Maßnahme	Status
Rollenmodell (Anbieter, Admin, Disponent, Fahrer) mit festgelegten Rechten; Fahrer sehen nur eigene und freigegebene Lieferungen	[U/G]
Mandantentrennung im Kern der Anwendung (`core/engine.js`): jede Abfrage und jede Aktion prüft die `tenantId` des angemeldeten Nutzers	[U/G]
Automatisierte Tests stellen sicher, dass ein Mandant keine Daten eines anderen Mandanten lesen oder ändern kann und dass Rollen keine fremden Rechte erhalten; Tests laufen vor jeder Auslieferung	[U/G]
Plattform-Konsole des Anbieters ohne Zugriff auf Auftragsdaten (nur Kennzahlen und Abrechnung)	[U/G]
Support-Zugriff nur nach Freigabe durch den Admin des Kunden, zeitlich begrenzt, nur lesend, protokolliert (AVV Anlage 4)	[U/G]
Dateien (Fotos, Dokumente, Unterschriften) werden nur nach Prüfung von Sitzung, Mandant und Rolle ausgeliefert; keine öffentlich erratbaren Datei-URLs	[U/G]
Live-Ereignisse (Server-Sent Events) und Push-Benachrichtigungen werden nur an berechtigte Nutzer desselben Mandanten zugestellt	[U/G]

2.4 Trennungskontrolle

Maßnahme	Status
Logische Trennung der Mandanten über `tenantId` in allen Tabellen, erzwungen im Anwendungskern (siehe 2.3)	[U/G]

Maßnahme	Status
Getrennte Umgebungen für Entwicklung, Test und Produktion; in Entwicklung und Test keine Echtdaten der Kunden	[U/G]
Online-Demo arbeitet mit lokaler Engine und erfundenen Demodaten, getrennt vom Produktivsystem	[U/G]

2.5 Pseudonymisierung und Datenminimierung

Maßnahme	Status
Keine Dauerortung; Standort nur im Moment eines Statuswechsels, nur wenn vom Kunden eingeschaltet und vom Fahrer im Gerät freigegeben	[U/G]
Fahrsperre wertet die Geschwindigkeit ausschließlich im Gerät aus; keine Übertragung oder Speicherung der dafür genutzten Positionen	[U/G]
Fotos werden im Gerät auf etwa 200 KB verkleinert; dabei werden Metadaten (EXIF, insbesondere GPS-Koordinaten) entfernt	[U/G]
Push-Nachrichten enthalten nur Kennungen und Status, keine Dokumente	[U/G]
Server-Protokolle ohne Inhalte von Formularen und Dokumenten; IP-Adressen werden nach [7] Tagen gelöscht	[U/G]
Aggregierte Kennzahlen je Mandant für Abrechnung ohne Personenbezug	[U/G]

3. Integrität (Art. 32 Abs. 1 lit. b DSGVO)

3.1 Weitergabekontrolle

Maßnahme	Status
TLS für alle Übertragungen zwischen Geräten, Server, Sicherungsziel und E-Mail-Versanddienst	[U/G]
Ende-zu-Ende-verschlüsselte Nutzlast bei Web-Push (RFC 8291); Push-Dienste können Inhalte nicht lesen	[U/G]
Datensicherungen werden vor der Übertragung mit [AES-256] verschlüsselt; Schlüssel getrennt von den Sicherungen verwahrt	[U/G]
Datenexport nur durch Admins; jeder Export wird protokolliert	[U/G]
Keine Einbindung externer Skripte, Schriften, Karten oder Tracker; Schriften werden vom eigenen Server ausgeliefert	[U/G]

3.2 Eingabekontrolle

Maßnahme	Status
Audit-Log für Anmeldungen, Änderungen an Lieferungen, Nutzern, Fahrzeugen und Einstellungen, Exporte, Freigaben und Support-Zugriffe, jeweils mit Zeitpunkt und handelnder Person	[U/G]
Verlauf jeder Lieferung als Zeitstrahl; Rücknahmen innerhalb von 2 Minuten werden als eigenes Ereignis gespeichert; spätere Korrekturen durch Disponenten werden protokolliert, der ursprüngliche Eintrag bleibt erhalten	[U/G]
Bei offline erfassten Schritten Speicherung von Gerätezeit und Server-Eingangszeit	[U/G]
[Prüfsumme (SHA-256) je Datei, Ausweis im Abliefernachweis]	[G]

3.3 Schutz der Anwendung

Maßnahme	Status
Content-Security-Policy ohne externe Quellen, z. B. `default-src 'self'; script-src 'self'; style-src 'self'; font-src 'self'; img-src 'self' data: blob:; connect-src 'self'; object-src 'none'; base-uri 'self'; frame-ancestors 'none'; form-action 'self'`	[U/G]
weitere Sicherheits-Header: `X-Content-Type-Options: nosniff`, `Referrer-Policy: [strict-origin-when-cross-origin]`, `Permissions-Policy` (Standort und Kamera nur für die eigene Herkunft)	[U/G]
Upload-Prüfung: erlaubte Dateitypen [JPEG, PNG, WebP, PDF], Prüfung des tatsächlichen Dateiinhalts (Signatur), Größenbegrenzung [10 MB], Speicherung außerhalb des Web-Verzeichnisses mit zufälligem Dateinamen	[U/G]
Schutz vor Cross-Site-Request-Forgery durch `SameSite`-Cookies [und Prüfung von `Origin`/Token]	[U/G]
Eingabevalidierung und parametrisierte Datenbankabfragen; Ausgabe-Kodierung gegen Cross-Site-Scripting	[U/G]
Begrenzung der Anfragen je Zugang und IP-Adresse	[U/G]
Wenige Abhängigkeiten (kein Framework); regelmäßige Prüfung der Abhängigkeiten auf bekannte Schwachstellen	[U/G]

4. Verfügbarkeit und Belastbarkeit (Art. 32 Abs. 1 lit. b DSGVO)

Maßnahme	Status
Rechenzentrum mit redundanter Strom- und Netzanbindung, USV, Klimatisierung, Brandfrüherkennung (Nachweis durch Zertifikat)	[U/G]
Mindestens tägliche, verschlüsselte Datensicherung von Datenbank und Dateien an einen räumlich getrennten Ort in Deutschland ([Backup-Anbieter]); Aufbewahrung 30 Tage rollierend	[U/G]
Überwachung der Erreichbarkeit im Minutentakt, Alarmierung der Bereitschaft	[U/G]
Offline-Warteschlange in der Fahrer-App überbrückt Funklöcher und kurze Unterbrechungen	[U/G]
Patch-Management: Sicherheitsaktualisierungen von Betriebssystem und Node.js 22 (LTS) innerhalb von [14] Tagen, bei kritischen Schwachstellen innerhalb von [72] Stunden	[U/G]
Speicherkontingente und Überlaufpuffer, damit Uploads laufender Zustellungen nicht scheitern	[U/G]
Schutz vor Überlastung durch Anfragebegrenzung [und vorgelagerten DDoS-Schutz des Hosting-Anbieters]	[U/G]

5. Wiederherstellbarkeit (Art. 32 Abs. 1 lit. c DSGVO)

Maßnahme	Status
Dokumentiertes Wiederherstellungsverfahren für Datenbank und Dateien	[U/G]
Wiederherstellungstests mindestens vierteljährlich, mit Protokoll (Datum, Dauer, Ergebnis)	[U/G]
Zielwerte: Wiederherstellungszeit [8 Stunden / Premium 4 Stunden], maximaler Datenverlust [24 Stunden / 15 Minuten]	[U/G]
Notfallplan mit Zuständigkeiten, Kontaktliste und Kommunikationsvorlagen	[U/G]

6. Verfahren zur regelmäßigen Überprüfung (Art. 32 Abs. 1 lit. d DSGVO)

Maßnahme	Status
Jährliche Überprüfung und Aktualisierung dieser TOM; zusätzlich bei wesentlichen Änderungen der Technik	[U/G]
Automatisierte Tests zu Rechten und Mandantentrennung bei jeder Änderung	[U/G]
[Jährlicher externer Sicherheitstest (Penetrationstest)]	[G]
Verfahren zur Behandlung von Sicherheitsvorfällen und Datenschutzverletzungen mit Meldung an Kunden innerhalb von [24] Stunden (AVV § 9)	[U/G]
Verfahren zur Entgegennahme und Behandlung von Schwachstellenmeldungen (`security.txt` , [Sicherheits-E-Mail]); für Store-Apps zusätzlich Meldewege nach Art. 14 CRA	[U/G]
Prüfung der Unterauftragsverarbeiter vor Beauftragung und danach [jährlich]	[U/G]

7. Auftragskontrolle und Organisation

Maßnahme	Status
Schriftliche bzw. elektronische Verträge nach Art. 28 DSGVO mit allen Unterauftragsverarbeitern	[U/G]
Verpflichtung aller Mitarbeiter und freien Mitarbeiter auf Vertraulichkeit und Datenschutz vor Aufnahme der Tätigkeit	[U/G]
Datenschutz- und Sicherheitsschulung bei Einstellung und danach jährlich	[U/G]
Berechtigungen nach dem Prinzip der minimalen Rechte; Entzug aller Zugänge beim Ausscheiden am letzten Arbeitstag	[U/G]
Verzeichnis von Verarbeitungstätigkeiten als Verantwortlicher (Art. 30 Abs. 1) und als Auftragsverarbeiter (Art. 30 Abs. 2)	[U/G]
Benennung eines Datenschutzkontakts bzw. Datenschutzbeauftragten: [Datenschutzkontakt]	[U/G]
Arbeitsplatzgeräte mit Festplattenverschlüsselung, Bildschirmsperre und aktuellen Updates	[U/G]

8. Löschkonzept

Datenart	Frist	Verfahren
Lieferungen mit Verlauf und Dokumenten	nach Einstellung des Kunden (Voreinstellung [3] Jahre, einstellbar 1–10 Jahre)	automatische Löschung im Produktivsystem; Ausnahme bei markiertem Streitfall
Standortangaben beim Statuswechsel	nach Einstellung des Kunden (Voreinstellung [90] Tage)	automatische Löschung der Koordinaten
Stammdaten deaktivierter Fahrer	[3] Monate nach Deaktivierung	automatische Löschung; Name verbleibt in Lieferungen bis zu deren Löschung
In-App-Benachrichtigungen	[90] Tage	automatisch
Audit-Log des Mandanten	[12] Monate	automatisch
Sitzungen	Abmeldung, PIN-Reset oder 90 Tage	automatisch

Datenart	Frist	Verfahren
Push-Abonnements	Abmeldung, Widerruf im Browser oder Rückmeldung des Push-Dienstes, dass das Abonnement ungültig ist	automatisch
Server-Protokolle mit IP-Adresse	[7] Tage	automatisch
Kundendaten nach Vertragsende	30 Tage Abrufzeitraum, danach Löschung innerhalb von [30] Tagen	Löschung des Mandanten und aller Dateien, Bestätigung auf Verlangen
Datensicherungen	30 Tage rollierend	Überschreiben im Sicherungszyklus
Datenträger	bei Austausch	Löschung bzw. Vernichtung durch das Rechenzentrum nach anerkanntem Standard (Nachweis durch Zertifikat)

9. Hinweise für Kunden (Maßnahmen im Verantwortungsbereich des Kunden)

1. Fahrer-Geräte mit Bildschirmsperre und Geräteverschlüsselung betreiben; die Offline-Warteschlange liegt unverschlüsselt im Speicher des Browsers und wird durch die Geräteverschlüsselung geschützt.
2. Bei Verlust eines Geräts PIN zurücksetzen; dadurch werden alle Sitzungen beendet.
3. Zugänge ausscheidender Mitarbeiter sofort deaktivieren.
4. Einladungslinks nicht in Gruppen-Chats teilen.
5. Dokumente mit Aufbewahrungspflicht regelmäßig exportieren und GoBD-konform archivieren.

> **Prüfhinweis (Technik):** Jede Zeile mit [U/G] vor Veröffentlichung bestätigen. Besonders prüfen: scrypt-Parameter, Gültigkeit der Einladungslinks, Entfernung von EXIF-Daten, lokale Auswertung der Fahrsperre, getrennte Löschfristen (in PLAN.md bisher nur `retentionYears`), Verschlüsselung der Sicherungen, Zwei-Faktor-Authentifizierung für die Plattform-Konsole.